

Small Business Cybersecurity Starter Kit

A practical, non-technical baseline for protecting accounts, devices, data, and people.

What this kit helps you do
Build a stronger security baseline without needing a cybersecurity team.
Identify the highest-impact actions first, then review your progress regularly.

Educational resource - not a substitute for professional security advice.

1. Start Here

Security is easier when you focus on a small number of high-impact controls first. Use this page as your baseline.

Priority order

- Protect administrator and email accounts with multi-factor authentication (MFA).
- Use unique passwords and a reputable password manager.
- Keep operating systems, browsers, applications, and firmware updated.
- Maintain at least one recoverable backup of important business data.
- Limit who has administrator access and review access when roles change.
- Create a simple procedure for suspicious emails, lost devices, and account compromise.
- Train people to recognize phishing, impersonation, and urgent payment requests.

Quick self-assessment

Area	Today	Target
Accounts	■ Weak / mixed	■ MFA + unique passwords
Devices	■ Unknown / outdated	■ Updated + inventory
Data	■ No tested backup	■ Regular + tested backup
People	■ Informal	■ Basic security guidance
Response	■ No plan	■ Written first-response steps

2. Account Security

Compromised email and administrator accounts can unlock many other systems. Protect your highest-value accounts first.

Checklist

- Enable MFA on email, cloud storage, business software, banking, and administrator accounts.
- Use a unique, long password for every important account.
- Store passwords in a reputable password manager instead of spreadsheets or notes.
- Remove old users and former employees from active accounts.
- Review recovery email addresses, phone numbers, and backup codes.
- Review sign-in alerts and recent sessions for unexpected activity.
- Avoid sharing passwords between employees or using shared personal accounts.

MFA priority

Start with email, administrator accounts, cloud storage, financial services, and remote-access tools. A single protected email account can help prevent password-reset attacks elsewhere.

Password rule of thumb

Prefer long and unique passwords. Length and uniqueness matter more than trying to invent complicated patterns that are reused across accounts.

Do not enter a real password into an unknown online password-checking site.

3. Device & Software Security

Every computer and phone connected to business data becomes part of your security boundary.

Checklist

- Turn on automatic updates where practical.
- Keep browsers and frequently used applications current.
- Use screen-lock protection and strong device authentication.
- Enable full-disk encryption when supported by the operating system.
- Remove software, browser extensions, and accounts that are no longer needed.
- Use reputable endpoint protection and keep it updated.
- Maintain a simple inventory of company devices and who is responsible for them.
- Avoid using unknown USB devices or installing software from untrusted sources.

Remote work

- Use trusted Wi-Fi and avoid sensitive work on open public networks when possible.
- Lock devices whenever you step away.
- Keep work data in approved storage rather than scattered across personal devices.

Lost or stolen device

Know in advance who should be contacted, how access can be revoked, and how the device can be remotely locked or wiped where supported.

4. Data, Backups & Sharing

Backups are useful only when they are recoverable. Treat backup testing as part of the process, not an optional extra.

Checklist

- Identify the business data that would be hardest to recreate.
- Back up important data on a regular schedule.
- Keep at least one backup separated from the primary environment.
- Restrict backup access to only the people who need it.
- Test restoring a small set of files periodically.
- Know how long you can operate if a major system is unavailable.
- Review cloud-sharing permissions and public links.
- Avoid sending sensitive files through unsecured or unknown services.

Data minimization

Collect and retain only the information you actually need. Fewer copies and fewer people with access mean fewer opportunities for accidental exposure.

Simple backup test

- Pick one important file.
- Restore it from the backup.
- Open it and confirm it is usable.
- Record the result and fix anything that failed.

5. People & Phishing

Technology cannot eliminate social engineering. Make suspicious behavior easy to report and verify.

Train people to pause when a message

- Creates unusual urgency or fear.
- Requests passwords, codes, money, gift cards, or sensitive information.
- Contains an unexpected attachment or link.
- Changes payment details or asks for a financial transfer.
- Uses a familiar name but arrives through an unusual channel.

Verification rule

For sensitive requests, verify through a separate trusted channel. Do not use the phone number, email address, or link contained in the suspicious message as your only source of verification.

Reporting culture

- Give employees one simple way to report suspicious messages.
- Encourage early reporting even when someone already clicked.
- Avoid blame; fast reporting can reduce damage.
- Review common incidents and update training accordingly.

6. Incident Response: First 30 Minutes

When something goes wrong, speed and clear priorities matter. Adapt these steps to your environment.

If an account may be compromised

- Stop interacting with suspicious messages or links.
- From a trusted device, change the affected password if appropriate.
- Revoke suspicious sessions or tokens where the service supports it.
- Confirm MFA and account-recovery settings have not been changed.
- Check recent activity for unexpected access.
- Preserve relevant messages and evidence rather than deleting everything immediately.
- Notify the person responsible for security or IT.

If malware or ransomware is suspected

- Disconnect the affected device from networks when safe to do so.
- Do not destroy logs or evidence unnecessarily.
- Avoid spreading the device's files to other systems.
- Assess which accounts and systems may have been exposed.
- Use known-good backups only after understanding the incident and recovery path.
- Seek qualified incident-response assistance when the impact is significant.

Important

Do not improvise destructive actions such as deleting logs, wiping devices, or restoring systems blindly when an investigation may be necessary.

7. Monthly Security Review

A small monthly review keeps security from becoming a once-a-year project.

- Review new and former employee accounts.
- Review administrator permissions.
- Review MFA coverage for important services.
- Check device inventory and missing devices.
- Confirm critical software is updated.
- Review backup status and complete at least one restore test.
- Review recent security alerts and suspicious messages.
- Check shared drives, public links, and third-party app permissions.
- Update the incident-response contact list.

Your next three actions

1	
2	
3	

CyberGuard Toolkit

Practical cybersecurity tools and resources for people who are not security experts.

This starter kit is educational. Your risks, legal obligations, and technical environment may require additional controls or professional advice.